CIP A106 Malware Analysis

Laboratory 4 Technical Report

Lokibot Trojan Decompilation and Controlled Debug Analysis

Details	
Analyst	Olaronke Olajide
Registration number	2026/EHIT/17106
Programme	Ethical Hacking Internship Training
Instructor	Aminu Idris
Laboratory dates	8 October 2026 (environment and sample handling); 9 October 2026 (debugger session)
Sample	Course Sample 3 (`Sample 3.zip`), extracted file `sample.bin`
Analysis environment	Oracle VirtualBox, VM FLARE-VM2 (Windows 10 22H2), isolated

1. Scope, Conventions and Summary

This report documents the isolated handling, AutoIt unpacking, static review, controlled debugger observation and memory validation of the course-provided Sample 3, designated for the exercise as a Lokibot Trojan. The live executable and any memory dump are **not** included in this submission.

Summary of results

Result	Basis	Confidence
The VM was isolated (clipboard, drag and drop, shared folders disabled) and a clean baseline snapshot was recorded before the sample was handled	EV-01, EV-02, EV-09	High (observed)
`sample.bin` is a 1,217,024-byte PE32 GUI executable with SHA-256 `9da91175…6da622a6`	EV-12, EV-20	High (observed)
`sample.bin` is an AutoIt-compiled program; its embedded script was extracted as `script.au3`	EV-15, EV-17	High
The script is obfuscated and builds a large hex blob that is passed to a decryption function with the hard-coded key `LRMKTJVUQI`	EV-18	Moderate
In the debugger the sample called `VirtualAlloc(0, 0x34108, 0x3000, 0x40)` and received base address 0x03000000	EV-22 to EV-24	High (observed)
That RWX allocation is consistent with staging a decrypted payload in memory	EV-23, EV-24	Moderate
Memory artifact acquisition and validation	Section 6	
Lokibot family attribution	Course designation only; no family-specific indicators observed	Low
Network communication, credential theft or persistence	Not observed	Not established

2. Section A: Environment and Initial Identification

A1. Isolation, hardening and clean snapshot

All hardening was applied while the VM was powered off and checked in VM Settings (Expert mode).

Control	Required	Observed	Evidence
Shared clipboard	Disabled	Disabled	EV-02
Drag and drop	Disabled	Disabled	EV-02
Shared folders	None	Global Folders and Machine Folders empty; no host folder mapped	EV-01
Network	No bridged, NAT or VPN	`ipconfig /all` inside the VM showed host name DESKTOP-OPD1N52, node type Hybrid, IP routing disabled, WINS proxy disabled, and no active IPv4 address in the visible output.	EV-07, EV-08
USB and storage	No removable media at baseline	USB filters not enabled; the storage controller held only `Flare VM-disk1.vmdk` in the final baseline	Analyst record
Sample transfer	No shared-folder bridge	ISO created with AnyBurn on the host (`Lab4_transfer.iso`, 841,728 bytes) and attached to SATA port 1 with `VBoxManage storageattach`; detached afterwards with `--medium none`. The VM saw it as drive D:.	EV-10

Clean snapshots. The final baseline is `CIP-A106-LAB04-CLEAN-BASELINE-20261008-0710-ISOLATED-FINAL`, taken after an earlier Lab 04 snapshot `CIP-A106-LAB04-CLEAN-BASELINE-20261008-0920`. Both were taken before the sample was transferred (EV-09). The snapshot tree is a chain from `CIP-A106-LAB01-CLEAN-BASELINE` through the Lab 02 and Lab 03 snapshots to the Lab 04 baselines.

A2. Operating system, analyst and tool versions

Item	Value	Evidence
Analyst	Olaronke Olajide; account `desktop-opd1n52\icdfa`	EV-06
Date and time	`Get-Date` returned 2026-10-08 06:35:18 (guest) during environment verification	EV-06
Guest operating system	Microsoft Windows 10 Home, version 22H2, OS Build 19045.2965 (`[System.Environment]::OSVersion` reports 10.0.19045.0); host name DESKTOP-OPD1N52; base memory 4096 MB	EV-02, EV-03, EV-06
Ghidra	11.3.2 (Build PUBLIC 2025-Apr-15 1250 EDT), Java 21.0.1	EV-04
Debugger	x32dbg from the x64dbg package, build Mar 15 2025 (TitanEngine), run elevated.	EV-05
Command shells and tools	Windows PowerShell 5.1; CMD; 7-Zip 23.01 (x64); `certutil`; Python 3.10 (`C:\Python310`)	EV-06, EV-12
Static and unpacking tools	FLOSS v3.1.1-0-g3cd3ee6; Detect It Easy (DIE, version); autoit-ripper **Exe2Aut was not available** in this FLARE-VM build (see Section B).	EV-13 to EV-17
Memory tool	Process Hacker 2	Section 6

A3. Sample handling, file type, size and hash

The course archive was handled only inside the isolated VM. The ISO was mounted as D:, and `Sample 3.zip` was copied with CMD (`copy D:\*.* "C:\Users\icdfa\Desktop\Samples\Sample3\"`). Its SHA-256 was calculated with `Get-FileHash` at 08:05:17 (guest) on 8 October 2026 (EV-10, EV-11). The executable was then extracted with 7-Zip into `C:\tmp\sample3`. The first extraction attempt in PowerShell failed with "No files to process" because the command wrapped across two lines; it was repeated in CMD and reported "Everything is Ok" (EV-12).

Property	Value
Archive	`Sample 3.zip`: 779,839 bytes, file date 10/08/2026 06:40 AM, ZIP archive

Property	Value
Archive SHA-256	`6EE4E1834DE2CC07C9BB2DFD7FC90B64 AF8ACA131A862C0D8676AF1349CA8606`
Archive used for extraction	`malware-sample-3 (1).zip`: 779,368 bytes.
Extracted file	`C:\tmp\sample3\malware-sample-3\sample.bin`, 1 file, 1,217,024 bytes
File type	PE32 executable (GUI) Intel 80386, for MS Windows (`file` command)
`sample.bin` **SHA-256 (certutil)**	`9da91175e7d72a7ff2bcb3fd93f2ba7b be4045f9c4dee5c9685c7fdf6da622a6`

A4. Assessment of the claimed Lokibot identification

Evidence	Observation	Effect on the claim
File characteristics	32-bit GUI PE of about 1.2 MB	Neutral
Static strings (FLOSS)	11,439 static strings including `>>>AUTOIT SCRIPT<<<`, `AUTOITCALLVARIABLE%d`, `GUI_RUNDEFMSG`	Shows an AutoIt-compiled executable; does not name a family
Packer or compiler detection	DIE reported an AutoIt v3 compiled script (analyst record)	Same as above
Embedded script	A script with random identifiers, a hex payload builder and a decryption call was extracted (Section B)	Consistent with a loader, not family-specific
Family indicators	No Lokibot-specific configuration, command-and-control address or credential-theft code was observed	Neither confirms nor refutes

Judgement. The sample is an AutoIt-compiled loader with an obfuscated script (**High** confidence for the AutoIt wrapper; **Moderate** for the loader role). AutoIt wrappers are used by several malware families, so the wrapper alone does not identify Lokibot. The Lokibot label comes from the assignment; independent confirmation was **not** obtained in this lab (**Low** confidence). Hash-reputation claims that appeared in earlier working notes (detection ratios, IP addresses, a URL) were not produced by any tool recorded in this lab, were linked to a hash that differs from the certutil record, and are excluded from this report.

3. Section B: AutoIt Unpacking and Decompilation

B1. Tool record

Item	Record
Source hash	`9da91175e7d72a7ff2bcb3fd93f2ba7b be4045f9c4dee5c9685c7fdf6da622a6`
Exe2Aut	**Not available.** `C:\Tools\exe2aut.exe` and `C:\Tools\AutoItExtractor\AutoItExtractor.exe` both returned "The system cannot find the path specified", and `where /r C:\Tools exe2aut.exe` found nothing (EV-16).
Tool used	`autoit-ripper` (Python 3.10), installed under `C:\Users\icdfa\Desktop\Tools\Packers\autoit-ripper\`; version
Command	`C:\Python310\Scripts\autoit-ripper.exe C:\tmp\sample3\malware-sample-3\sample.bin C:\tmp\`
Result	`INFO:root:Storing result in C:/tmp/script.au3`; `dir C:\tmp\ /b` listed `script.au3` and `script.bin` (EV-17)
Processing time	
Output location	`C:\tmp\`

B2. Resulting files

File	Size	SHA-256
`sample.bin` (original, kept separate)	1,217,024 bytes	`9da91175e7d72a7ff2bcb3fd93f2ba7b be4045f9c4dee5c9685c7fdf6da622a6`
`script.au3` (extracted script)		`788d259be4f29de5865fa18c4b0089f6 a1f0d10c910376250ae6924f1e5b6099`
`script.bin`		

The script hash was recorded with `certutil -hashfile` between 16:09:19 and 16:21:48 on 9 October 2026 (EV-20). The troubleshooting steps are kept as evidence of method: `[System.Convert]::FromHexString` is not available in Windows PowerShell 5.1 (`MethodNotFound`), a quoted hex replace failed with `MissingExpressionAfterToken`, and a Python typo (`binascil`) raised `ModuleNotFoundError` (EV-19).

B3. Significant findings from the extracted script

The following was read from `script.au3` in a text editor (EV-18). It is an **analytical lead**, corroborated by the debugger evidence in Section 5 but not proven by the decompilation alone.

Observation	Detail	Type
Randomised identifiers	Variable and function names such as `$GPYBUOKYOFQWL`, `$BVRLGYGFK`, `$O0ACKVMND`, `EWFUGMIBNE`, `SRWNHMJLGX`, `RACRZJACLW`, `AYUDERGFV`; junk statements such as `IsString("fasepwd…")`	Observed
Indirect execution	`$POE = Execute("execute")` and calls of the form `$POE($AYUDERGFV("0x536C65…"))`, where hex-encoded text is decoded by a custom function and then executed	Observed
API and library names	Strings for `netapi32.dll`, `gdi32.dll`, `kernel32.dll`, `UrlCompareW`, `UrlCanonicalizeW`, `CreateFileW`, `DeviceIoControl`	Observed
Payload builder	A variable `$J` is extended by many `$J = $J & "<hex>"` lines	Observed
Decryption call	`$J = EWFUGMIBNE($J, "LRMKTJVUQI", "-1")` followed by a call to `SRWNHMJLGX()`	Observed
Possible target process	A hex string starting `0x4053797374656d44…` begins with `@SystemDir`; your notes read the whole string as `@SystemDir & "\dllhost.exe"`	Observed in part; the full decode is not verified

Judgement. The script hides its logic behind hex-encoded strings and `Execute`, which defeats simple string searching (**High**). It carries an encrypted payload and decrypts it with a hard-coded key (**Moderate**; the algorithm was not identified and the payload was not recovered statically). A reference to `dllhost.exe` is only partly verified, because the decode attempts used hand-typed hex that produced truncated or garbled output (EV-19); this is **Low to Moderate** evidence of a process-injection target. 4. Section C: Ghidra Static Analysis and IOC Assessment

C1. Ghidra project record

Item	Record
Ghidra version	11.3.2 (EV-04)
Project name	
Imported artifact	
Analysis options and date	

C2. Static findings so far (not from Ghidra)

Until the Ghidra results are added, these findings come from FLOSS (`static.txt`) and the script review:

Source	Observation
FLOSS static run (0.33 s)	File `sample.bin`; language unknown; 11,439 static strings (96,915 characters); stack, tight and decoded string extraction disabled (EV-13)
FLOSS full run (138.45 s)	11,439 static strings, 1,946 stack strings, 59 tight strings, 33 decoded strings (EV-14)
Section names in `static.txt`	`.text`, `.rdata`, `.data`, `.rsrc`, `.reloc` (EV-15)
PEStudio	The file did not finish loading in PEStudio (it hung); the reason was not established. Entropy figures in earlier working notes have no recorded source and are not used.

C3. Indicator table

Type	Value	Source artifact and location	Status	Confidence
SHA-256	`6EE4E183…49CA8606` (`Sample 3.zip`)	`Get-FileHash`, EV-11	Observed	High
SHA-256	`9da91175…6da622a6` (`sample.bin`)	certutil, EV-20	Observed	High
SHA-256	`788d259b…1e5b6099` (`script.au3`)	certutil, EV-20	Observed	High
File names	`sample.bin`, `script.au3`, `script.bin`	`C:\tmp\`, EV-17	Observed	High
Marker string	`>>>AUTOIT SCRIPT<<<`	FLOSS `static.txt`, EV-15	Observed	High (AutoIt)
Key	`LRMKTJVUQI`	`script.au3`, call to `EWFUGMIBNE`, EV-18	Observed	Moderate
Function names	`EWFUGMIBNE`, `SRWNHMJLGX`, `RACRZJACLW`, `AYUDERGFV`	`script.au3`, EV-18	Observed	Low (likely randomised per build)
Process name	`dllhost.exe` (from a hex string)	`script.au3`, EV-18	Partly verified	Low to Moderate
Domains, IPs, URLs, registry paths, mutexes	None observed	Static strings and script review	Not observed	n/a

`255.255.255.255` appears among the static strings but no context was established, so it is not treated as a network indicator.

C4. Two findings in plain language

- **Finding 1: the script hides what it does.** Instead of calling functions by name, the script keeps text as hex and runs it through `Execute`. Anyone searching the file for words such as "VirtualAlloc" or "http" would find nothing. This is **observed** in the script. That it is done to avoid detection is a **judgement** (Moderate).
- **Finding 2: the script carries an encrypted payload.** It builds a long hex string and passes it with the key `LRMKTJVUQI` to a decryption function, then calls another function. The decrypted result is not visible in the file. That the result is a second-stage program is a **judgement** (Moderate), supported by the executable memory allocation in Section 5 but not yet proven.

5. Section D: Controlled Debugger Observation

D1. Session record

Item	Record
Debugger	x32dbg (x64dbg build Mar 15 2025, TitanEngine), elevated, inside FLARE-VM2 only
Session time (guest)	Hash verification window: Fri 10/09/2026 16:09:19.14 to 16:21:48.36. The debugger "Time Wasted Debugging" counter read 0:00:10:54 at the VirtualAlloc observation.
Source hash before starting	`9da91175e7d72a7ff2bcb3fd93f2ba7b` `be4045f9c4dee5c9685c7fdf6da622a6`

Item	Record
Process	`sample.bin`, PID 504, main thread 3968, entry point 0x00D17DCD (title bar and CPU view, EV-21)

D2. Anti-debugging and anti-analysis checks

No anti-debugging or anti-analysis check was identified in the recorded session. The sample ran under the debugger to the VirtualAlloc breakpoint without a crash or an exit. Items in earlier notes were reviewed and are **not** treated as evidence: runs of CC (int3) bytes around the entry code are normal compiler padding, and the `jmp dword ptr [<&VirtualAlloc>]` seen at the start of `kernel32.VirtualAlloc` is the standard forwarding stub to KERNELBASE. This is an absence of evidence from a short session, not proof that the sample has no such checks (**Low** confidence).

D4. VirtualAlloc observation

A breakpoint was set from the Symbols tab: module `kernel32.dll`, filter `VirtualAlloc`, toggle breakpoint (F2) on the export at 0x75DFF9F0 (EV-22). After F9 the debugger stopped with the message "INT3 breakpoint at <kernel32.VirtualAlloc> (75DFF9F0)" (EV-23). The values below are those shown by the tool.

Parameter	Displayed value	Meaning
Module and address	`kernel32.dll` 0x75DFF9F0	Exported `VirtualAlloc`
`lpAddress`	0x00000000	The system chooses the address
`dwSize`	0x00034108	213,256 bytes (about 208 KiB). Your earlier notes gave 213,512, which is an arithmetic error.
`flAllocationType`	0x00003000	MEM_COMMIT | MEM_RESERVE
`flProtect`	0x00000040	PAGE_EXECUTE_READWRITE
Other	0x00DB5310 in the fifth stack slot and in EDI	An address inside `sample.bin`; its role is not established

Judgement (Moderate). A private allocation that is both writable and executable is consistent with a program preparing to place and run decrypted code. It is not proof on its own, because some legitimate software also allocates RWX memory. The module base address was not recorded, so addresses are given as virtual addresses only.

6. Section E: Memory Artifact Validation and Technical Report

E1. Hardware breakpoint on the allocated region

After the VirtualAlloc call returned to the sample, the debugger showed EIP 0x00D10CB9 (`sample.bin`, relative address 0x20CB9) and EAX 0x03000000, the base address of the new region (EV-24). A write hardware breakpoint was requested with:

```
bphws 03000000, w, 1
```

The debugger log answered "Hardware breakpoint already set!" (EV-25). **Observed:** a hardware breakpoint was in place at 0x03000000. This record does not by itself show that the breakpoint was triggered, and no sample code was modified. E2. Memory acquisition

Item	Record
Process	`sample.bin`, PID 504 (from the x32dbg title bar)
Parent process	

Item	Record
Region	Base 0x03000000; size requested 0x34108 (213,256 bytes); protection requested RWX.
Acquisition time (guest)	debugger counter 0:00:18:22 in your notes
Output file	
Size and SHA-256	
Scope	Only this process region was saved. No other process and no user data were collected.

E3. Safe validation of the artifact

The dump must be examined statically and must not be run. Your notes describe expected results (an MZ header, a DOS-mode string, `dllhost.exe`), but the acquisition and checks were not yet recorded, so none is reported as a result here.

Check	Method	Result
PE structure	Check for `4D 5A` at offset 0 and a valid PE header (hex view, or PEStudio read-only)	**add**
String review	`strings` or FLOSS static on the dump; look for `dllhost.exe`, API names, URLs	**add**
Comparison	Compare with `sample.bin` and `script.au3` (hash, size, shared strings)	**add**

Limits of the method. The dump is a point-in-time copy. If it was taken at the first write to the region, the payload may be only partly decrypted. A raw region dump is not a rebuilt PE file and may not parse cleanly. No network or process-injection behaviour was executed.

E4. Findings matrix

ID	Finding	Source artifact	Confidence	Limitation
F-01	Archive and extracted sample hashed before analysis	EV-11, EV-12, EV-20	High	`sample.bin` hash first character to be confirmed; second archive name and size differ
F-02	`sample.bin` is an AutoIt-compiled PE32 GUI file	EV-12, EV-15	High	DIE version and screenshot to be added
F-03	Embedded script extracted (`script.au3`)	EV-17, EV-20	High	Exe2Aut unavailable; alternative tool; `script.bin` undocumented
F-04	Script obfuscated, builds hex blob, decrypts with key `LRMKTJVUQI` (T1027, T1027.013)	EV-18	Moderate	Algorithm and decrypted content not determined
F-05	Reference to `dllhost.exe` in the script (possible injection target, T1055)	EV-18, EV-19	Low	Hex decode not verified; no injection observed
F-06	`VirtualAlloc(0, 0x34108, 0x3000, 0x40)` at 0x75DFF9F0; EAX 0x03000000 afterwards	EV-22 to EV-24	High (observed)	One call observed in a short session
F-07	RWX allocation consistent with staging a decrypted payload (T1140)	EV-23, EV-24	Moderate	Write event and dump validation pending
F-08	No anti-debugging check identified	EV-21 to EV-24	Low	Short, limited trace
F-09	Lokibot family attribution	Assignment only	Low	No family-specific indicators observed
F-10	No network, credential-theft or persistence behaviour observed	All sections	n/a	Isolated VM; no network monitoring; payload not run

E5. MITRE ATT&CK mapping

Technique	Evidence	Confidence
T1059.010 Command and Scripting Interpreter: AutoHotKey & AutoIT	AutoIt-compiled executable; extracted `script.au3`	High
T1027 Obfuscated Files or Information (and T1027.013 Encrypted/Encoded File)	Randomised names, hex-encoded strings, encrypted payload blob with hard-coded key	Moderate to High
T1140 Deobfuscate/Decode Files or Information	Decryption call in the script; RWX allocation in the debugger	Moderate
T1055 Process Injection	Only a string reference to `dllhost.exe`; no injection observed	Low

Not mapped, because there is no supporting evidence: persistence (T1547.001), file and directory discovery (T1083), ingress tool transfer (T1105), shared modules (T1129), sandbox evasion (T1497.001) and any credential-access or command-and-control technique. Earlier working notes proposed these without evidence. The record of `wininet.dll` or `ws2_32.dll` being loaded does not show network use.

E6. Conclusion

Sample 3 (`sample.bin`, SHA-256 `9da91175…6da622a6`) is a 32-bit AutoIt-compiled executable whose embedded script, extracted with autoit-ripper, is obfuscated and prepares an encrypted payload that is decrypted with the hard-coded key `LRMKTJVUQI` (**Moderate**). Under x32dbg the sample allocated 213,256 bytes of private memory with execute, read and write protection through `VirtualAlloc` and received the region at 0x03000000, which is consistent with staging a decrypted second stage (**High** that the allocation occurred, **Moderate** for its purpose).

The analysis did **not** observe network communication, credential theft, persistence or a confirmed injection, and it did not independently confirm the Lokibot family (**Low**). Key limitations: Exe2Aut was unavailable, Ghidra findings are still to be added, the payload was not recovered, the session was short, and no network monitoring was in place. The environment was isolated throughout. The VM was restored to the clean snapshot at the end of the lab.

Appendix A: Evidence Index

Screenshots are cited as EV-nn and are kept as separate files. Add each file name and SHA-256 to Appendix B. Items in the last group are still to be captured.

ID	Content	Section
EV-01	VM Settings > Shared Folders: Global and Machine folders empty	A1
EV-02	VM Settings > General: clipboard and drag and drop disabled; base memory 4096 MB	A1
EV-03	About Windows: Windows 10 22H2, build 19045.2965	A2
EV-04	About Ghidra 11.3.2	A2
EV-05	About x64dbg / x32dbg	A2
EV-06	PowerShell: `whoami`, `Get-Date`, OS version	A2
EV-07, EV-08	`ipconfig /all` output (two screenshots)	A1
EV-09	VirtualBox snapshot tree with the Lab 04 baselines	A1
EV-10	Transfer: `copy D:\*.*` and `dir` of the Sample3 folder	A3
EV-11	`Get-FileHash` of `Sample 3.zip` at 08:05:17	A3
EV-12	7-Zip extraction, `dir`, `certutil`, `file` for `sample.bin`	A3
EV-13, EV-14	FLOSS static run (0.33 s) and full run (138.45 s)	C2
EV-15	`static.txt` strings	C2
EV-16	Exe2Aut and AutoItExtractor path errors; `where /r C:\Tools exe2aut.exe`	B1
EV-17	autoit-ripper output; `dir C:\tmp\ /b`	B1
EV-18	`script.au3` in a text editor	B3
EV-19	PowerShell and Python decode attempts and errors	B2
EV-20	CMD `certutil` hashes of `sample.bin` and `script.au3` (16:09 to 16:21)	A3, B2
EV-21	x32dbg title bar: PID 504, main thread 3968, entry point	D1
EV-22	x32dbg Symbols tab: `VirtualAlloc` breakpoint on `kernel32.dll`	D4
EV-23	x32dbg at 0x75DFF9F0 with the stack arguments	D4
EV-24	x32dbg after return: EIP 0x00D10CB9, EAX 0x03000000	E1
EV-25	x32dbg log: "Hardware breakpoint already set!"	E1
EV-26 to EV-56	To capture: Ghidra project; hardware breakpoint hit; Process Hacker; hash of the dump; validation results	C1, E1 to E3

Screenshots EV-01 to EV-56